

@actual-app/sync-server's missing authorization on GET /secret/:name allows non-admin OpenID users to enumerate admin-configured bank-sync secrets

Report Type: Weekly · Generated: June 22, 2026 22:45 UTC · Coverage: Jun 22 - Jun 22, 2026

1 Total Advisories	0 Critical	0 High	1 Medium
MEDIUM Severity	4.3 CVSS / Risk Score	TLP:CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Summary In `@actual-app/sync-server`, the `GET /secret/:name` endpoint (`app-secrets.js:53`) checks only that the caller has a valid session — it does not verify the caller is an admin. The sibling `POST /secret/` handler does enforce an admin check in OpenID mode, exposing an authorization asymmetry. Any authenticated non-admin (BASIC) user in OpenID multi-user deployments can probe the secrets store and learn which admin-managed bank-sync integrations have been configured (existence, not values). This includes integration credentials that are not otherwise observable to non-admins, such as `simplefin_accessKey`, `pluggyai_clientSecret`, `pluggyai_itemIds`, and the `gocardless_*` secrets. ## Details `packages/sync-server/src/app-secrets.js` mounts `validateSessionMiddleware` at the router level (line 15), so all handlers inherit only "must be authenticated." The POST handler then explicitly upgrades to an admin check when the active auth method is `openid`: ````js // app-secrets`

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
@actual-app/sync-server's missing authorization on CDB/secret/:name endpoint	Critical	10.0	-	## Summary In `@actual-app/sync-server`, the `GET /secret/:name` endpoint (

MITRE ATT&CK® v15 Mapping

Technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	-

Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intell/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - CDB-ADVISORY Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: Detects exploitation indicators related to CDB-ADVISORY.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/06/22
tags:
- attack.initial_access
- attack.t1190
logsource:
category: webserver
detection:
keywords:
- 'CDB-ADVISORY'
condition: keywords
falsepositives:
- Security testing / penetration testing
level: medium
```

Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - @actual-app/sync-server's missing authorization on GET /secret/:name allows non-admin OpenID users to
// enumerate admin-configured bank-sync secrets
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "@actual-app/sync-server's missing author"
or AlertName has "@actual-app/sync-server's missing author"
or ExtendedProperties has "@actual-app/sync-server's missing author"
| extend Rule = "APEX-ADVISORY", Severity = "MEDIUM"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 - 0-24 Hours (Containment)

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield @actual instances exposed to the internet.
3. Enable verbose access logging on all @actual endpoints immediately.

- 4. Pull last 72h of web server and application logs for forensic baselining.
- 5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
- 6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 - 24-72 Hours (Eradication)

- 1. Apply vendor patch for @actual or implement recommended mitigation.
- 2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
- 3. Rotate all API keys, service account credentials, and session tokens.
- 4. Conduct forensic timeline reconstruction for potential compromise window.
- 5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 - 7 Days (Recovery & Hardening)

- 1. Conduct post-incident review and update incident response runbooks.
- 2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
- 3. Update asset inventory with patched version information and closure evidence.
- 4. Submit findings to internal risk register and CISO dashboard.
- 5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

\$150K - \$900K Breach Cost Range (FAIR)	\$380K IBM Cost of Breach 2025 Median	\$120K/day Business Interruption Cost	\$85K Regulatory Fine Exposure
--	---	---	--

Medium severity events require internal investigation and targeted customer notification. Average cost includes 340 hours of engineering time.

Remediation Cost Estimate: \$55K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
PCI-DSS v4.0	Req. 6.3.3	Non-critical patches applied within 3 months
NIST CSF 2.0	ID.RA / PR.PS	Vulnerability assessment and platform security policies
ISO 27001:2022	A.8.8	Vulnerability management programme with documented remediation timelines

CYBERDUDEBIVASH® SENTINEL APEX // CONFIDENTIAL - FOR AUTHORIZED USE ONLY

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Monitor @actual-app/sync-server's missing authorization on GET /secret/:name allows non-admin OpenID users to enumerate admin-configured bank-sync secrets for escalation.
2. Apply patches in next maintenance window.
3. Apply vendor patch for @actual-app/sync-server's missing authorization on GET /secret/:name allows non-admin OpenID users to enumerate admin-configured bank-sync secrets immediately - check NVD for official fix guidance.
4. Enable enhanced logging and alerting on all systems running affected software versions.
5. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
6. Audit all internet-facing instances of affected products and confirm patch deployment.
7. Conduct a threat hunt using MITRE ATT&CK techniques mapped in this advisory.

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--acde9bb9d075d556d2672ef1
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-06-22T22:45:40.71457
Customer Tier	PRO
Customer Email	-
TLP	TLP: CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries: enterprise@cyberdudebivash.com